CHANGE REPORT

✓ Fixed

Coupon applied twice at checkout, and any customer could download another customer's invoice

PROJECT ShopFlow online store (demo) BRANCH `fix/checkout-coupon-invoice-access` COMMIT `a71c0d9` DATE 2026-10-29

PREPARED BY Claude (AI coding agent) REQUESTED BY Maria Lopez, QA lead

01 Summary

Two defects were found while the checkout and order-history pages were tested before release. Both are fixed on this branch.

When a shopper refreshed the cart page, the coupon was applied a second time, so 1,240 orders in the test run were charged too little (USD 3,180 in total). Separately, the invoice download link accepted any order number: a logged-in shopper could change the number in the address bar and download someone else's invoice, with their name, address and items.

The coupon is now calculated once from the cart subtotal and stored with the order, and every invoice is loaded only through the signed-in customer's own orders. New tests cover both rules, and a person repeated the checks by hand with two separate customer accounts.

AT A GLANCE

2
Problems found
1 critical · 1 high

3
Fixes made
cover 2 of 2 problems

5 / 7
Checks passed
1 partial · 1 not run

2
Permission requests
1 approved · 1 safer option

1 → 0
Scan HIGH findings
before → after

02 What was wrong

Each problem as it was found, before anything was changed.

HIGH P1 Coupon discount applied twice when the cart is refreshed

WHERE `applyCoupon()` in `src/services/cart.ts` FOUND BY Test FIXED BY F1 F3

SYMPTOM

A 10% coupon on a USD 50.00 cart gave a total of USD 40.50 instead of USD 45.00 after the page was refreshed once.

ROOT CAUSE

`applyCoupon()` took the discount off the current cart total instead of the original subtotal, and it ran again on every cart refresh. Nothing recorded that the coupon was already applied.

IMPACT

In the staging test run, 1,240 of 9,800 orders were under-charged, USD 3,180 in total. In production this would be lost revenue and manual refunds or re-billing.

EVIDENCE

> Test order SF-20261029-0417: subtotal 50.00, coupon SAVE10, charged 40.50.
> The cart log shows `applyCoupon` called twice for the same cart within 4 seconds.

CRITICAL P2 Invoice download did not check who owns the order

WHERE `GET /api/orders/:id/invoice` in `src/routes/orders.ts` FOUND BY Human FIXED BY F2 F3

SYMPTOM

Signed in as test customer A, opening `/api/orders/1002/invoice` downloaded the invoice of customer B.

ROOT CAUSE

The route loaded the order with `Order.findById(req.params.id)` and only checked that someone was signed in, not that the order belonged to them. Order numbers are sequential, so they are easy to guess.

IMPACT

Any customer could read other customers' names, addresses, phone numbers and purchases: a personal-data leak that would have to be reported in many countries.

EVIDENCE

> Request as customer A (id 77) for order 1002 (owned by customer 81) returned HTTP 200 with the PDF.

03 What we fixed

What changed, why it is the right fix, and the code before and after.

F1 Calculate the coupon once, from the subtotal

FIXES P1 Coupon discount applied twice when the cart is refreshed

CHANGE The discount is now calculated from `cart.subtotal`, and the applied coupon is stored on the cart. Applying the same coupon again changes nothing. A unique index on (cart_id, coupon_code) blocks duplicates at database level.

WHY IT IS CORRECT The total no longer depends on how many times the page loads, and the database refuses a second copy even if two requests arrive together.

FILES `src/services/cart.ts` `migrations/20261029_add_cart_coupon_unique.ts` `tests/cart.coupon.test.ts`

− BEFORE TYPESCRIPT

```
  export function applyCoupon(cart: Cart, coupon: Coupon) {
-   cart.total = cart.total * (1 - coupon.percent / 100);
    return cart;
  }
```

+ AFTER TYPESCRIPT

```
  export function applyCoupon(cart: Cart, coupon: Coupon) {
+   if (cart.couponCode === coupon.code) return cart;
+   cart.couponCode = coupon.code;
+   cart.total = cart.subtotal * (1 - coupon.percent / 100);
    return cart;
  }
```

F2 Load invoices only through the customer's own orders

FIXES P2 Invoice download did not check who owns the order

CHANGE The route now looks the order up with both the order id and the signed-in customer's id, and answers 404 when it does not match.

WHY IT IS CORRECT A customer can only reach orders that belong to them. The 404 response does not reveal whether another customer's order exists.

FILES `src/routes/orders.ts` `tests/orders.invoice.test.ts`

− BEFORE TYPESCRIPT

```
  router.get('/orders/:id/invoice', requireLogin, async (req, res) => {
-   const order = await Order.findById(req.params.id);
    res.download(invoicePath(order));
  });
```

+ AFTER TYPESCRIPT

```
  router.get('/orders/:id/invoice', requireLogin, async (req, res) => {
+   const order = await Order.findOne({ _id: req.params.id, customerId: req.user.id });
+   if (!order) return res.sendStatus(404);
    res.download(invoicePath(order));
  });
```

F3 **Tests for both rules**

FIXES

P1 Coupon discount applied twice when the cart is refreshed

P2 Invoice download did not check who owns the order

CHANGE

Added tests: refreshing the cart three times keeps one discount; customer A gets 404 for customer B's invoice and 200 for their own.

WHY IT IS CORRECT

Both tests failed on the old code and pass on the new code, so they guard against the same defect coming back.

FILES

`tests/cart.coupon.test.ts` `tests/orders.invoice.test.ts`

04 Verification

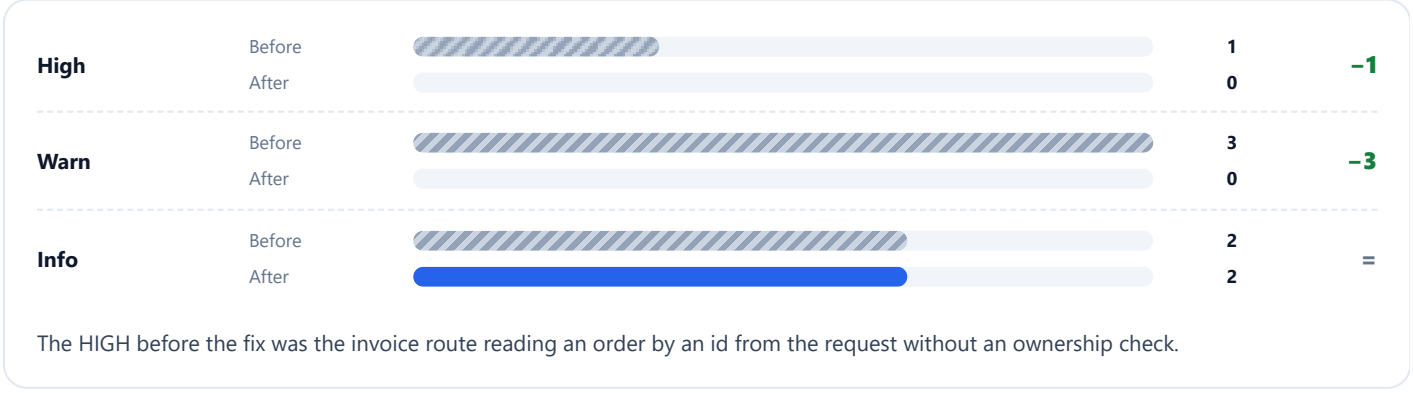
How the change was checked, by the AI agent and by people.

7 checks: 3 by the AI, 3 by people, 1 by both.

CHECK	PERSPECTIVE	RESULT	DETAIL
Automated tests (npm test)	AI	✓ Pass	214 tests, 0 failures; the 2 new tests failed before the fix.
safe-ai-coding review scan (diff-check)	AI	✓ Pass	No HIGH or WARN findings left; 2 INFO about outbound calls, both expected.
Missing-symbol check	AI	✓ Pass	Every function, import and route used in the change exists.
Manual test with two customer accounts	Human	✓ Pass	Customer A could not open customer B's invoice; both could open their own.
Checkout refreshed 5 times with a coupon	Human	✓ Pass	Total stayed at USD 45.00 on a USD 50.00 cart with SAVE10.
Code read by a second developer	AI + human	◐ Partial	Approved, with one note: rename `invoicePath` to `invoiceFilePath` later.
Load test of checkout	Human	○ Not run	Planned for the release candidate.

05 Scans before and after

Red-flag scan of the change, before and after the fix.



The HIGH before the fix was the invoice route reading an order by an id from the request without an ownership check.

06 Approvals

Risky actions the agent asked permission for, and the harm it named.

ACTION	POSSIBLE HARM	DECISION	WHEN
Run the new migration on the local database	Adds a unique index; fails if duplicate rows already exist	✓ Approved	2026-10-29 11:05
Run the same migration on the shared staging database	Locks the carts table for a few seconds; other testers see the change at once	↪ Safer option	2026-10-29 11:20

07 Files changed

FILE	ADDED	REMOVED	SHARE
`src/services/cart.ts`	+6	−2	
`src/routes/orders.ts`	+3	−1	
`migrations/20261029_add_cart_coupon_unique.ts`	+14	−0	
`tests/cart.coupon.test.ts`	+38	−0	
`tests/orders.invoice.test.ts`	+31	−0	
Total	**+92**	**−3**	

08 Remaining risks

What is still not covered. Read these before relying on the change.

! Orders already charged too little in staging must be corrected before the data is copied anywhere else.

! Other download routes (receipts, shipping labels) use the same pattern and have not been checked yet.

09 Next steps

1. Run the migration on staging during the quiet hour, as agreed.
2. Review the receipts and shipping-label routes for the same ownership check.
3. Run the checkout load test before release.